

TRex SE

Application Info

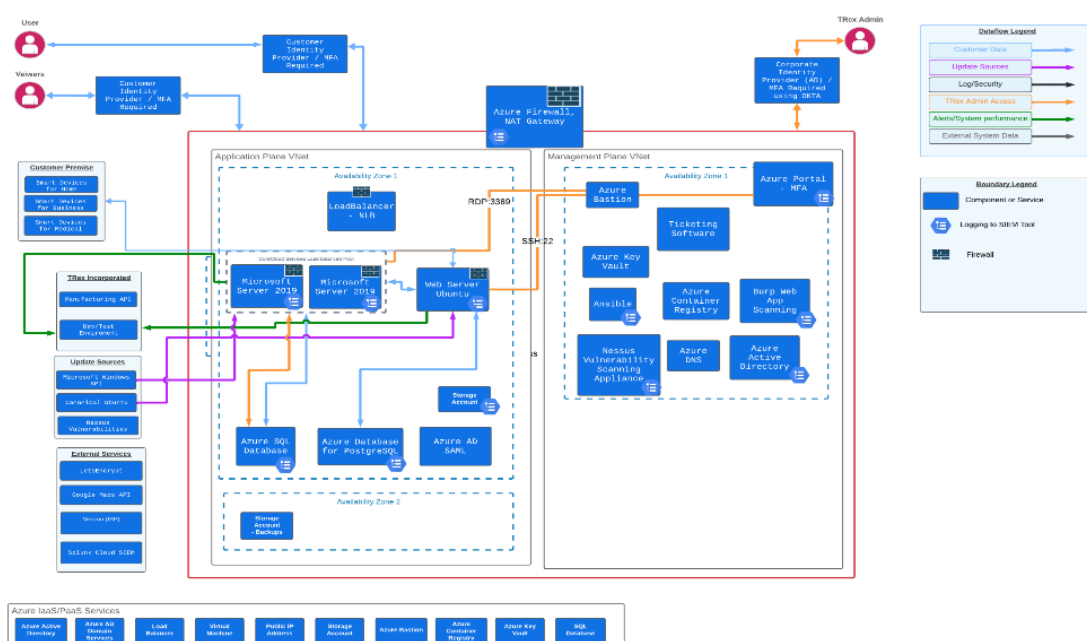
TRex, Inc. develops smart devices to be used for homes and businesses and in the medical industry. These smart devices include alarm systems, appliances, and human-worn devices. They also collect personal identifiable information (PII), protected health information (PHI), credit card information, device and security information, and other sensitive data. The devices can be configured to be linked to first responders, family members, or any authorized users that a business and/or the owner of the device chooses.

Architecture

Introduction

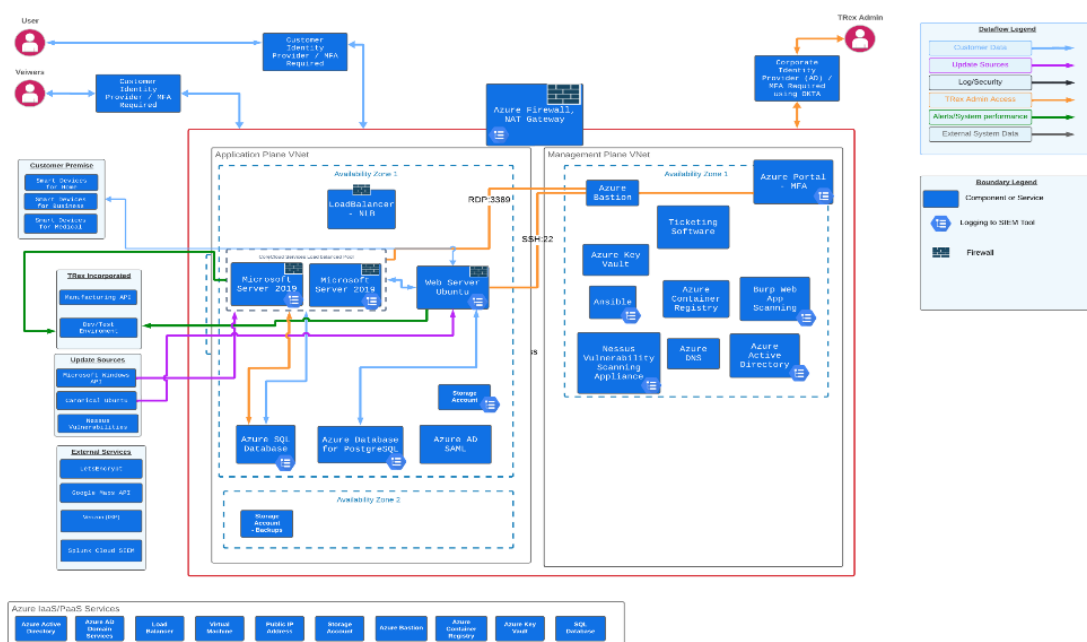
The devices that deploy TRex's software are configured to communicate with the TRex Smart Everything (TRex SE) Software as a Service (SaaS) platform that is hosted on the Azure Commercial Cloud Infrastructure as a Service (IaaS) platform. All TRex administrators log into the management plane of the TRex SE using TRex's active directory configured for multifactor authentication (MFA) using OKTA. Customers must use MFA and must provide their own identity provider (if applicable). All customer users will be configured to use MFA to gain access to their device as well as TRex SE, according to their choice, with no exceptions. FIPS 140-2 validated encryption is used throughout the environment, and all events from each host within the environment are logged and sent to Splunk. Within the TRex SE platform, all technology is updated automatically using advanced programmable interfaces (APIs). The home and business devices use their own internet service provider (ISP); however, due to the sensitive nature of the medical devices and their purposes, TRex will utilize Verizon ISP for internet connectivity with these devices. No data leaves the United States borders per service level agreements (SLA).

Architecture Diagram



Introduction

Dataflow Diagram



Assumptions

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
-------------------	------------	----------------	--------------------	----------

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
A-0020	All data storage and processing remain within the United States in compliance with TRex's Service Level Agreement (SLA) and data-protection policies.	T-0020 : A Third-party cloud provider data backup or replication misconfigured to use foreign servers can transfer sensitive data outside the United States, which leads to may violate company policy or data protection laws, resulting in reduced confidentiality of cloud storage systems, data backups	M-0020 : Restrict data storage to U.S. regions only and audit cloud configurations for compliance.	https://www.tenable.com/plugins/nessus/43111
A-0019	All logging and monitoring systems are configured with real-time alerts and redundancy to detect abnormal activity or performance issues.	T-0019 : An internal actor alert system not configured correctly or fails to detect anomalies can suspicious system activity goes unnoticed for long periods, which leads to attackers remain in the system without detection, resulting in reduced availability of Splunk, monitoring dashboards, log storage	M-0019 : Enable real-time alerts and redundant monitoring systems to detect abnormal activity quickly.	https://www.tenable.com/plugins/nessus/233660
A-0018	All application input fields and APIs implement strict input validation and sanitization to	T-0018 : An External actor web application or API does not filter or sanitize user input can	M-0018 : Apply input validation and parameterized queries to all forms and API	https://www.tenable.com/plugins/nessus/10297

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
	prevent code injection or data manipulation.	enters malicious code or commands into web forms or API calls, which leads to data can be modified, deleted, or corrupted within the system, resulting in reduced integrity of TRex SE web application, backend database	endpoints.	
A-0017	Verizon ISP is used exclusively for medical devices to ensure secure, encrypted, and reliable communication, with no data leaving U.S. borders.	T-0017: An External actor Verizon connection not configured securely for medical device communication can intercepts or disrupts network traffic used by medical devices, which leads to medical data transmission could be delayed, altered, or lost, resulting in reduced availability of Verizon ISP network, connected medical devices	M-0017: Secure Verizon ISP connections with VPN tunnels and continuous monitoring for medical devices.	 https://www.tenable.com/plugins/nessus/10114 
A-0016	All third-party software dependencies and open-source libraries are monitored for vulnerabilities and patched promptly after	T-0016: An External actor third-party or open source software contains unpatched vulnerabilities can exploits outdated or	M-0016: Use a software composition analysis tool to track third-party vulnerabilities and apply patches promptly.	 https://www.tenable.com/plugins/nessus/197900 

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
	disclosure.	vulnerable components to access TRex SE, which leads to may allow attackers to run malicious code or extract sensitive data, resulting in reduced integrity of application servers, open source libraries		
A-0015	All TRex employees and administrators receive security awareness training to prevent insider threats and reduce human error.	T-0015: An internal actor employee has not completed or understood security awareness training can falls for phishing emails or shares sensitive information accidentally, which leads to could lead to unauthorized access, data loss, or malware infection, resulting in reduced confidentiality of workstations, employee email, internal network	M-0015: Provide mandatory cybersecurity training for all employees and run phishing simulations.	 https://www.tenable.com/plugins/nessus/166250 
A-0014	All user accounts in the TRex SE environment must follow strong password policies, including length, complexity, and periodic expiration.	T-0014: An External actor users set weak or reused passwords can attempts repeated logins or automated password attacks to gain access, which leads to	M-0014: Implement strong password policy (length, complexity, expiration) and enforce password history.	 https://www.tenable.com/plugins/nessus/156860 

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
		unauthorized users could access TRex SE accounts or data, resulting in reduced confidentiality of Okta login system, user accounts		
A-0013	Only authorized administrators can access the management plane, and all accounts follow least-privilege access principles.	T-0013: An internal actor admin account has excessive permissions can misuses privileges or leaks data, which leads to full system compromise possible, resulting in reduced integrity of management plane, user database	M-0013: Review admin roles quarterly and apply least-privilege access principles.	 https://www.tenable.com/cve/CVE-2023-22602 
A-0012	All logs generated from TRex SE systems are automatically forwarded to Splunk for continuous security monitoring and auditing.	T-0012: An internal actor log forwarding disabled or broken can system events is not monitored, which leads to security incidents remain unnoticed, resulting in reduced availability of splunk, log sources	M-0012: Configure automatic log forwarding and alert admins if forwarding fails.	 https://www.tenable.com/cve/CVE-2024-36990 
A-0011	The TRex SE API update process uses secure code signing and configuration management to	T-0011: An External actor update system lacks signature verification can pushes a fake or malicious	M-0011: Require code-signing for API updates and verify digital signatures before	 https://www.tenable.com/cve/CVE-2024-28863 

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
	prevent unauthorized updates or tampering.	update, which leads to devices or apps run unauthorized code, resulting in reduced integrity of API updates server	deployment.	
A-0010	All customer and medical device data are encrypted at rest and in transit using FIPS 140-2 validated encryption algorithms.	T-0010: An internal actor encryption keys missing or not applied correctly can stores or sends data in plain text, which leads to disclosure of medical or personal information, resulting in reduced confidentiality of database, data storage	M-0010: Encrypt all stored and transmitted data using FIPS 140-2 algorithms (AES-256 or stronger).	https://www.tenable.com/plugins/nessus/234190
A-0009	All SSH services use key-based authentication and strong cipher suites to prevent brute-force or unauthorized access.	T-0009: An External actor weak SSH key or reused credentials can Brute-forces SSH login, which leads to server compromise and data theft, resulting in reduced confidentiality of SSH server	M-0009: Use key-based SSH authentication with strong ciphers and rotate keys regularly.	https://www.tenable.com/cve/CVE-2023-48795
A-0008	Remote Desktop Protocol (RDP) and other administrative interfaces are restricted to internal VPN access and protected by MFA.	T-0008: An External actor RDP connection not restricted by VPN can connects remotely using stolen or weak credentials, which leads to unauthorized	M-0008: Limit RDP access through VPN only and require MFA for all remote logins.	https://www.tenable.com/plugins/nessus/18405

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
		access to admin systems, resulting in reduced confidentiality of RDP server, admin systems		
A-0007	All network ports and services are reviewed regularly, and unnecessary open ports are closed or blocked by a firewall.	T-0007 : An External actor Firewall misconfiguration or ports left open can scans for and exploits open services., which leads to attackers gain access or disrupt operations, resulting in reduced availability of firewall, TRex SE web server	M-0007 : Conduct monthly port scans and firewall reviews to close unused ports.	https://www.tenable.com/plugins/nessus/10297
A-0006	IP forwarding is disabled on all TRex systems unless it is explicitly required for routing.	T-0006 : A Misconfiguration IP forwarding is accidentally turned on can forwards private traffic outside the secure network, which leads to data may leak to unauthorized locations, resulting in reduced confidentiality of routers, internal network	M-0006 : Use configuration management tools to ensure IP forwarding remains disabled.	https://www.tenable.com/cve/CVE-1999-0511
A-0005	Splunk Enterprise servers are patched to the latest version and restricted to authorized TRex administrators	T-0005 : An internal actor Weak access control or outdated Splunk version can deletes or alters security log files,	M-0005 : Restrict Splunk access to authorized admins and enable tamper-proof log storage.	https://www.tenable.com/plugins/nessus/194923

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
	only.	which leads to investigations and alerts are delayed or inaccurate, resulting in reduced integrity of Splunk log server		
A-0004	All operating systems, applications, and libraries (including Apache Log4j, Apache Commons Text, and Node.js modules) are regularly patched and updated to their latest secure versions.	T-0004 : An External actor TRex server runs unpatched or outdated software can exploits known vulnerability to gain access, which leads to compromise of system files or user data, resulting in reduced integrity of TRex SE application server	M-0004 : Apply regular patch management and vulnerability scans to keep software updated.	https://www.tenable.com/cve/CVE-2022-42889
A-0003	All SSL/TLS certificates used in TRex SE are valid, trusted, and issued by a recognized Certificate Authority (CA).	T-0003 : An internal actor SSL certificate expires or is self-signed can creates a fake TRex SE login site to steal credentials, which leads to users may provide login information to attackers, resulting in reduced integrity of logging page, SSL certificate store.	M-0003 : Implement automated certificate renewal and monitor for expired or untrusted certs.	https://www.tenable.com/plugins/nessus/51192
A-0002	All web communications between TRex SE and	T-0002 : An External actor Server uses weak or	M-0002 : Require FIPS 140-2 validated TLS	https://www.tenable.com/cve/CVE-2007-1858

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
	customer devices use FIPS 140-2 validated HTTPS/TLS encryption for secure data transfer.	outdated TLS protocol can Intercepts and views data between devices and TRex SE, which leads to sensitive customer or medical data may be exposed, resulting in reduced confidentiality of Web server, network traffic, user devices.	1.2 or higher for all connections and disable older protocols	
A-0001	All TRex administrators and customers must use multifactor authentication (MFA) through Okta before accessing the management plane or TRex SE.	T-0001: An internal actor Admin disables MFA settings in Okta or Active Directory. can Logs into the system without using multi factor verification, which leads to Unauthorized access could lead to stolen or exposed sensitive information, resulting in reduced confidentiality of Okta login system, TRex SE management plane.	M-0001: Enforce MFA for all admin and customer accounts in Okta; audit MFA settings monthly.	 https://www.tenable.com/cve/CVE-2005-1794 

Threats

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
T-0020	A Third-party cloud provider data backup or replication	M-0020: Restrict data storage to U.S. regions only	A-0020: All data storage and processing remain within	Resolved	Medium	I	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	misconfigured to use foreign servers can transfer sensitive data outside the United States, which leads to may violate company policy or data protection laws, resulting in reduced confidentiality of cloud storage systems, data backups	and audit cloud configurations for compliance.	the United States in compliance with TRex's Service Level Agreement (SLA) and data-protection policies.				
T-0019	An internal actor alert system not configured correctly or fails to detect anomalies can suspicious system activity goes unnoticed for long periods, which leads to attackers remain in the system without detection, resulting in reduced availability of Splunk, monitoring dashboards, log storage	M-0019 : Enable real-time alerts and redundant monitoring systems to detect abnormal activity quickly.	A-0019 : All logging and monitoring systems are configured with real-time alerts and redundancy to detect abnormal activity or performance issues.	Resolved	Medium	I	
T-0018	An External actor web application or API does not filter or sanitize user input can enters malicious code or commands into web forms or API calls, which leads to data	M-0018 : Apply input validation and parameterized queries to all forms and API endpoints.	A-0018 : All application input fields and APIs implement strict input validation and sanitization to prevent code injection or data manipulation.	Resolved	High	T	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	can be modified, deleted, or corrupted within the system, resulting in reduced integrity of TRex SE web application, backend database						
T-0017	An External actor Verizon connection not configured securely for medical device communication can intercepts or disrupts network traffic used by medical devices, which leads to medical data transmission could be delayed, altered, or lost, resulting in reduced availability of Verizon ISP network, connected medical devices	M-0017 : Secure Verizon ISP connections with VPN tunnels and continuous monitoring for medical devices.	A-0017 : Verizon ISP is used exclusively for medical devices to ensure secure, encrypted, and reliable communication, with no data leaving U.S. borders.	Resolved	Medium	D	
T-0016	An External actor third-party or open source software contains unpatched vulnerabilities can exploits outdated or vulnerable components to access TRex SE, which leads to may allow attackers to run malicious code or extract	M-0016 : Use a software composition analysis tool to track third-party vulnerabilities and apply patches promptly.	A-0016 : All third-party software dependencies and open-source libraries are monitored for vulnerabilities and patched promptly after disclosure.	Resolved	High	E	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	sensitive data, resulting in reduced integrity of application servers, open source libraries						
T-0015	An internal actor employee has not completed or understood security awareness training can falls for phishing emails or shares sensitive information accidentally, which leads to could lead to unauthorized access, data loss, or malware infection, resulting in reduced confidentiality of workstations, employee email, internal network	M-0015 : Provide mandatory cybersecurity training for all employees and run phishing simulations.	A-0015 : All TRex employees and administrators receive security awareness training to prevent insider threats and reduce human error.	Resolved	Medium	I	
T-0014	An External actor users set weak or reused passwords can attempts repeated logins or automated password attacks to gain access, which leads to unauthorized users could access TRex SE accounts or data, resulting in reduced confidentiality of Okta login system, user accounts	M-0014 : Implement strong password policy (length, complexity, expiration) and enforce password history.	A-0014 : All user accounts in the TRex SE environment must follow strong password policies, including length, complexity, and periodic expiration.	Resolved	Medium	S	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
T-0013	An internal actor admin account has excessive permissions can misuses privileges or leaks data, which leads to full system compromise possible, resulting in reduced integrity of management plane, user database	M-0013 : Review admin roles quarterly and apply least-privilege access principles.	A-0013 : Only authorized administrators can access the management plane, and all accounts follow least-privilege access principles.	Resolved	High	E	
T-0012	An internal actor log forwarding disabled or broken can system events is not monitored, which leads to security incidents remain unnoticed, resulting in reduced availability of splunk, log sources	M-0012 : Configure automatic log forwarding and alert admins if forwarding fails.	A-0012 : All logs generated from TRex SE systems are automatically forwarded to Splunk for continuous security monitoring and auditing.	Resolved	Medium	I	
T-0011	An External actor update system lacks signature verification can pushes a fake or malicious update, which leads to devices or apps run unauthorized code, resulting in reduced integrity of API updates server	M-0011 : Require code-signing for API updates and verify digital signatures before deployment.	A-0011 : The TRex SE API update process uses secure code signing and configuration management to prevent unauthorized updates or tampering.	Resolved	High	T	
T-0010	An internal actor encryption keys missing or not applied correctly	M-0010 : Encrypt all stored and transmitted	A-0010 : All customer and medical device data are	Resolved	High	I	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	can stores or sends data in plain text, which leads to disclosure of medical or personal information, resulting in reduced confidentiality of database, data storage	data using FIPS 140-2 algorithms (AES-256 or stronger).	encrypted at rest and in transit using FIPS 140-2 validated encryption algorithms.				
T-0009	An External actor weak SSH key or reused credentials can Brute-forces SSH login, which leads to server compromise and data theft, resulting in reduced confidentiality of SSH server	M-0009 : Use key-based SSH authentication with strong ciphers and rotate keys regularly.	A-0009 : All SSH services use key-based authentication and strong cipher suites to prevent brute-force or unauthorized access.	Resolved	High	S	
T-0008	An External actor RDP connection not restricted by VPN can connects remotely using stolen or weak credentials, which leads to unauthorized access to admin systems, resulting in reduced confidentiality of RDP server, admin systems	M-0008 : Limit RDP access through VPN only and require MFA for all remote logins.	A-0008 : Remote Desktop Protocol (RDP) and other administrative interfaces are restricted to internal VPN access and protected by MFA.	Resolved	High	E	
T-0007	An External actor Firewall misconfiguration or ports left open can scans for and exploits open services.,	M-0007 : Conduct monthly port scans and firewall reviews to close unused	A-0007 : All network ports and services are reviewed regularly, and unnecessary open ports are	Resolved	Medium	D	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	which leads to attackers gain access or disrupt operations, resulting in reduced availability of firewall, TRex SE web server	ports.	closed or blocked by a firewall.				
T-0006	A Misconfiguration IP forwarding is accidentally turned on can forwards private traffic outside the secure network, which leads to data may leak to unauthorized locations, resulting in reduced confidentiality of routers, internal network	M-0006 : Use configuration management tools to ensure IP forwarding remains disabled.	A-0006 : IP forwarding is disabled on all TRex systems unless it is explicitly required for routing.	Resolved	Medium	I	
T-0005	An internal actor Weak access control or outdated Splunk version can deletes or alters security log files, which leads to investigations and alerts are delayed or inaccurate, resulting in reduced integrity of Splunk log server	M-0005 : Restrict Splunk access to authorized admins and enable tamper-proof log storage.	A-0005 : Splunk Enterprise servers are patched to the latest version and restricted to authorized TRex administrators only.	Resolved	Medium	T	
T-0004	An External actor TRex server runs unpatched or outdated software can exploits known	M-0004 : Apply regular patch management and vulnerability scans to keep software	A-0004 : All operating systems, applications, and libraries (including Apache Log4j,	Resolved	High	E	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	vulnerability to gain access, which leads to compromise of system files or user data, resulting in reduced integrity of TRex SE application server	updated.	Apache Commons Text, and Node.js modules) are regularly patched and updated to their latest secure versions.				
T-0003	An internal actor SSL certificate expires or is self-signed can creates a fake TRex SE login site to steal credentials, which leads to users may provide login information to attackers, resulting in reduced integrity of logging page, SSL certificate store.	M-0003 : Implement automated certificate renewal and monitor for expired or untrusted certs.	A-0003 : All SSL/TLS certificates used in TRex SE are valid, trusted, and issued by a recognized Certificate Authority (CA).	Resolved	Medium	S	
T-0002	An External actor Server uses weak or outdated TLS protocol can Intercepts and views data between devices and TRex SE, which leads to sensitive customer or medical data may be exposed, resulting in reduced confidentiality of Web server, network traffic, user devices.	M-0002 : Require FIPS 140-2 validated TLS 1.2 or higher for all connections and disable older protocols	A-0002 : All web communications between TRex SE and customer devices use FIPS 140-2 validated HTTPS/TLS encryption for secure data transfer.	Resolved	High	I	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
T-0001	An internal actor Admin disables MFA settings in Okta or Active Directory. can Logs into the system without using multi factor verification, which leads to Unauthorized access could lead to stolen or exposed sensitive information, resulting in reduced confidentiality of Okta login system, TRex SE management plane.	M-0001 : Enforce MFA for all admin and customer accounts in Okta; audit MFA settings monthly.	A-0001 : All TRex administrators and customers must use multifactor authentication (MFA) through Okta before accessing the management plane or TRex SE.	Resolved	High	E	

Mitigations

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
-------------------	------------	--------------------	-------------	--------	----------

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
M-0020	Restrict data storage to U.S. regions only and audit cloud configurations for compliance.	T-0020 : A Third-party cloud provider data backup or replication misconfigured to use foreign servers can transfer sensitive data outside the United States, which leads to may violate company policy or data protection laws, resulting in reduced confidentiality of cloud storage systems, data backups	A-0020 : All data storage and processing remain within the United States in compliance with TRex's Service Level Agreement (SLA) and data-protection policies.	Resolved	
M-0019	Enable real-time alerts and redundant monitoring systems to detect abnormal activity quickly.	T-0019 : An internal actor alert system not configured correctly or fails to detect anomalies can suspicious system activity goes unnoticed for long periods, which leads to attackers remain in the system without detection, resulting in reduced availability of Splunk, monitoring dashboards, log storage	A-0019 : All logging and monitoring systems are configured with real-time alerts and redundancy to detect abnormal activity or performance issues.	Resolved	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
M-0018	Apply input validation and parameterized queries to all forms and API endpoints.	T-0018 : An External actor web application or API does not filter or sanitize user input can enters malicious code or commands into web forms or API calls, which leads to data can be modified, deleted, or corrupted within the system, resulting in reduced integrity of TRex SE web application, backend database	A-0018 : All application input fields and APIs implement strict input validation and sanitization to prevent code injection or data manipulation.	Resolved	
M-0017	Secure Verizon ISP connections with VPN tunnels and continuous monitoring for medical devices.	T-0017 : An External actor Verizon connection not configured securely for medical device communication can intercepts or disrupts network traffic used by medical devices, which leads to medical data transmission could be delayed, altered, or lost, resulting in reduced availability of Verizon ISP network, connected medical devices	A-0017 : Verizon ISP is used exclusively for medical devices to ensure secure, encrypted, and reliable communication, with no data leaving U.S. borders.	Resolved	
M-0016	Use a software composition analysis tool	T-0016 : An External actor third-party or open source	A-0016 : All third-party software dependencies	Resolved	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
	to track third-party vulnerabilities and apply patches promptly.	software contains unpatched vulnerabilities can exploits outdated or vulnerable components to access TRex SE, which leads to may allow attackers to run malicious code or extract sensitive data, resulting in reduced integrity of application servers, open source libraries	and open-source libraries are monitored for vulnerabilities and patched promptly after disclosure.		
M-0015	Provide mandatory cybersecurity training for all employees and run phishing simulations.	T-0015 : An internal actor employee has not completed or understood security awareness training can falls for phishing emails or shares sensitive information accidentally, which leads to could lead to unauthorized access, data loss, or malware infection, resulting in reduced confidentiality of workstations, employee email, internal network	A-0015 : All TRex employees and administrators receive security awareness training to prevent insider threats and reduce human error.	Resolved	
M-0014	Implement strong password policy (length, complexity, expiration)	T-0014 : An External actor users set weak or reused passwords can attempts	A-0014 : All user accounts in the TRex SE environment must follow strong	Resolved	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
	and enforce password history.	repeated logins or automated password attacks to gain access, which leads to unauthorized users could access TRex SE accounts or data, resulting in reduced confidentiality of Okta login system, user accounts	password policies, including length, complexity, and periodic expiration.		
M-0013	Review admin roles quarterly and apply least-privilege access principles.	T-0013: An internal actor admin account has excessive permissions can misuses privileges or leaks data, which leads to full system compromise possible, resulting in reduced integrity of management plane, user database	A-0013: Only authorized administrators can access the management plane, and all accounts follow least-privilege access principles.	Resolved	https://www.tenable.com/cve/CVE-2023-22602
M-0012	Configure automatic log forwarding and alert admins if forwarding fails.	T-0012: An internal actor log forwarding disabled or broken can system events is not monitored, which leads to security incidents remain unnoticed, resulting in reduced availability of splunk, log sources	A-0012: All logs generated from TRex SE systems are automatically forwarded to Splunk for continuous security monitoring and auditing.	Resolved	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
M-0011	Require code-signing for API updates and verify digital signatures before deployment.	T-0011 : An External actor update system lacks signature verification can pushes a fake or malicious update, which leads to devices or apps run unauthorized code, resulting in reduced integrity of API updates server	A-0011 : The TRex SE API update process uses secure code signing and configuration management to prevent unauthorized updates or tampering.	Resolved	
M-0010	Encrypt all stored and transmitted data using FIPS 140-2 algorithms (AES-256 or stronger).	T-0010 : An internal actor encryption keys missing or not applied correctly can stores or sends data in plain text, which leads to disclosure of medical or personal information, resulting in reduced confidentiality of database, data storage	A-0010 : All customer and medical device data are encrypted at rest and in transit using FIPS 140-2 validated encryption algorithms.	Resolved	
M-0009	Use key-based SSH authentication with strong ciphers and rotate keys regularly.	T-0009 : An External actor weak SSH key or reused credentials can Brute-forces SSH login, which leads to server compromise and data theft, resulting in reduced confidentiality of SSH server	A-0009 : All SSH services use key-based authentication and strong cipher suites to prevent brute-force or unauthorized access.	Resolved	
M-0008	Limit RDP access through VPN only and	T-0008 : An External actor RDP connection not restricted by	A-0008 : Remote Desktop Protocol (RDP) and other	Resolved	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
	require MFA for all remote logins.	VPN can connects remotely using stolen or weak credentials, which leads to unauthorized access to admin systems, resulting in reduced confidentiality of RDP server, admin systems	administrative interfaces are restricted to internal VPN access and protected by MFA.		
M-0007	Conduct monthly port scans and firewall reviews to close unused ports.	T-0007 : An External actor Firewall misconfiguration or ports left open can scans for and exploits open services., which leads to attackers gain access or disrupt operations, resulting in reduced availability of firewall, TRex SE web server	A-0007 : All network ports and services are reviewed regularly, and unnecessary open ports are closed or blocked by a firewall.	Resolved	
M-0006	Use configuration management tools to ensure IP forwarding remains disabled.	T-0006 : A Misconfiguration IP forwarding is accidentally turned on can forwards private traffic outside the secure network, which leads to data may leak to unauthorized locations, resulting in reduced confidentiality of routers, internal network	A-0006 : IP forwarding is disabled on all TRex systems unless it is explicitly required for routing.	Resolved	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
M-0005	Restrict Splunk access to authorized admins and enable tamper-proof log storage.	T-0005 : An internal actor Weak access control or outdated Splunk version can deletes or alters security log files, which leads to investigations and alerts are delayed or inaccurate, resulting in reduced integrity of Splunk log server	A-0005 : Splunk Enterprise servers are patched to the latest version and restricted to authorized TRex administrators only.	Resolved	
M-0004	Apply regular patch management and vulnerability scans to keep software updated.	T-0004 : An External actor TRex server runs unpatched or outdated software can exploits known vulnerability to gain access, which leads to compromise of system files or user data, resulting in reduced integrity of TRex SE application server	A-0004 : All operating systems, applications, and libraries (including Apache Log4j, Apache Commons Text, and Node.js modules) are regularly patched and updated to their latest secure versions.	Resolved	
M-0003	Implement automated certificate renewal and monitor for expired or untrusted certs.	T-0003 : An internal actor SSL certificate expires or is self-signed can creates a fake TRex SE login site to steal credentials, which leads to users may provide login information to attackers, resulting in reduced	A-0003 : All SSL/TLS certificates used in TRex SE are valid, trusted, and issued by a recognized Certificate Authority (CA).	Resolved	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
		integrity of logging page, SSL certificate store.			
M-0002	Require FIPS 140-2 validated TLS 1.2 or higher for all connections and disable older protocols	T-0002 : An External actor Server uses weak or outdated TLS protocol can Intercepts and views data between devices and TRex SE, which leads to sensitive customer or medical data may be exposed, resulting in reduced confidentiality of Web server, network traffic, user devices.	A-0002 : All web communications between TRex SE and customer devices use FIPS 140-2 validated HTTPS/TLS encryption for secure data transfer.	Resolved	
M-0001	Enforce MFA for all admin and customer accounts in Okta; audit MFA settings monthly.	T-0001 : An internal actor Admin disables MFA settings in Okta or Active Directory. can Logs into the system without using multi factor verification, which leads to Unauthorized access could lead to stolen or exposed sensitive information, resulting in reduced confidentiality of Okta login system, TRex SE management plane.	A-0001 : All TRex administrators and customers must use multifactor authentication (MFA) through Okta before accessing the management plane or TRex SE.	Resolved	

Impacted Assets

Assets Number	Asset	Related Threats
AS-0001	cloud storage systems, data backups	T-0020 : A Third-party cloud provider data backup or replication misconfigured to use foreign servers can transfer sensitive data outside the United States, which leads to may violate company policy or data protection laws, resulting in reduced confidentiality of cloud storage systems, data backups
AS-0002	Splunk, monitoring dashboards, log storage	T-0019 : An internal actor alert system not configured correctly or fails to detect anomalies can suspicious system activity goes unnoticed for long periods, which leads to attackers remain in the system without detection, resulting in reduced availability of Splunk, monitoring dashboards, log storage
AS-0003	TRex SE web application, backend database	T-0018 : An External actor web application or API does not filter or sanitize user input can enters malicious code or commands into web forms or API calls, which leads to data can be modified, deleted, or corrupted within the system, resulting in reduced integrity of TRex SE web application, backend database
AS-0004	Verizon ISP network, connected medical devices	T-0017 : An External actor Verizon connection not configured securely for medical device communication can intercepts or disrupts network traffic used by medical devices, which leads to medical data transmission could be delayed, altered, or lost, resulting in reduced availability of Verizon ISP network, connected medical devices
AS-0005	application servers, open source libraries	T-0016 : An External actor third-party or open source software contains unpatched vulnerabilities can exploits outdated or vulnerable components to access TRex SE, which leads to may allow attackers to run malicious code or extract sensitive data, resulting in reduced integrity of application servers, open source libraries
AS-0006	workstations, employee email, internal network	T-0015 : An internal actor employee has not completed or understood security awareness training can falls for phishing emails or shares sensitive information accidentally, which leads to could lead to unauthorized access, data loss, or malware infection, resulting in reduced confidentiality of workstations, employee email, internal network
AS-0007	Okta login system, user accounts	T-0014 : An External actor users set weak or reused passwords can attempts repeated logins or automated password attacks to gain access, which leads to unauthorized users could access TRex SE accounts or data, resulting in reduced confidentiality of Okta login system, user accounts
AS-0008	management plane, user database	T-0013 : An internal actor admin account has excessive permissions can misuses privileges or leaks data, which leads to full system compromise possible, resulting in reduced integrity of management plane, user database
AS-0009	splunk, log sources	T-0012 : An internal actor log forwarding disabled or broken can system events is not monitored, which leads to security incidents remain unnoticed, resulting in reduced availability of

Assets Number	Asset	Related Threats
		splunk, log sources
AS-0010	API updates server	T-0011 : An External actor update system lacks signature verification can pushes a fake or malicious update, which leads to devices or apps run unauthorized code, resulting in reduced integrity of API updates server
AS-0011	database, data storage	T-0010 : An internal actor encryption keys missing or not applied correctly can stores or sends data in plain text, which leads to disclosure of medical or personal information, resulting in reduced confidentiality of database, data storage
AS-0012	SSH server	T-0009 : An External actor weak SSH key or reused credentials can Brute-forces SSH login, which leads to server compromise and data theft, resulting in reduced confidentiality of SSH server
AS-0013	RDP server, admin systems	T-0008 : An External actor RDP connection not restricted by VPN can connects remotely using stolen or weak credentials, which leads to unauthorized access to admin systems, resulting in reduced confidentiality of RDP server, admin systems
AS-0014	firewall, TRex SE web server	T-0007 : An External actor Firewall misconfiguration or ports left open can scans for and exploits open services., which leads to attackers gain access or disrupt operations, resulting in reduced availability of firewall, TRex SE web server
AS-0015	routers, internal network	T-0006 : A Misconfiguration IP forwarding is accidentally turned on can forwards private traffic outside the secure network, which leads to data may leak to unauthorized locations, resulting in reduced confidentiality of routers, internal network
AS-0016	Splunk log server	T-0005 : An internal actor Weak access control or outdated Splunk version can deletes or alters security log files, which leads to investigations and alerts are delayed or inaccurate, resulting in reduced integrity of Splunk log server
AS-0017	TRex SE application server	T-0004 : An External actor TRex server runs unpatched or outdated software can exploits known vulnerability to gain access, which leads to compromise of system files or user data, resulting in reduced integrity of TRex SE application server
AS-0018	logging page, SSL certificate store.	T-0003 : An internal actor SSL certificate expires or is self-signed can creates a fake TRex SE login site to steal credentials, which leads to users may provide login information to attackers, resulting in reduced integrity of logging page, SSL certificate store.
AS-0019	Web server, network traffic, user devices.	T-0002 : An External actor Server uses weak or outdated TLS protocol can Intercepts and views data between devices and TRex SE, which leads to sensitive customer or medical data may be exposed, resulting in reduced confidentiality of Web server, network traffic, user devices.
AS-0020	Okta login system, TRex SE management	T-0001 : An internal actor Admin disables MFA settings in Okta or Active Directory. can Logs into the system without using multi factor verification, which leads to Unauthorized access

Assets Number	Asset	Related Threats
	plane.	could lead to stolen or exposed sensitive information, resulting in reduced confidentiality of Okta login system, TReX SE management plane.